

TABLE I
WHAT THE DESIGN-TIME ANALYSIS FOUND IN 7 REAL SYSTEMS, RANKED BY IMPACT. EVERY INSTANCE WAS CHECKED AGAINST THE SYSTEM'S OWN SOURCE.

#	Weakness	CWE	Instances	Systems affected	Evidence in source
1	Payment or ledger traffic in clear text	319	6	4 of 4 with a confidentiality rule	Confirmed 6/6: insecure gRPC credentials (Online Boutique, OTel Demo), <code>http://</code> calls (Bank of Anthos, Sock Shop)
2	Data layer reachable without crossing the authentication service	306	1	TeaStore (the one system whose authentication is not verified at the callee)	Confirmed: webui calls persistence directly, no auth code in persistence. Token-based Bank of Anthos is correctly not reported (JWT verified at each backend)
3	Public entry point guarded by no authentication rule	306	8	7 of 7	3 with no login code at all, 4 with a login on some routes
4	Single-copy component on the user-facing critical path	–	28	7 of 7	Confirmed 28/28: 9 explicit <code>replicas:</code> 1, 19 default of 1
5	Store reachable from the entry outside its own service (multi-hop via rule)	923	2	Sock Shop, Social Network	Sock Shop: by design (session store). Social Network confirmed in code: a second service reads the user store
	Checks that stayed silent (exposed store, unintended exposure, contradictory policy, vacuous)		0	0 of 7	Fire on their fault in the pilot (c4, c5, c7, c12)